

Security Advisory: Linux Kernel

Vulnerability CVE-2026-31431 (Copy Fail)

Document Version: 1.0

Release Date: 2026-04-30

Risk Level: Critical

1. Vulnerability Overview

Vulnerability ID: CVE-2026-31431

Vulnerability Name: Copy Fail

Vulnerability Type: Local Privilege Escalation (LPE), Container Escape

Description: A critical security flaw exists in the Linux kernel crypto subsystem ``authenc`` AEAD template. The vulnerability was introduced in 2017 via an in-place optimization in the ``algif_aead`` module. Attackers can craft a small Python script (about 732 bytes) to trigger an out-of-bounds memory write by using ``splice()`` zero-copy with AF_ALG socket.

This flaw allows 100% reliable local privilege escalation to root without kernel offsets or race conditions. It can also be exploited for container escape by tampering with host shared page cache, compromising the entire node in container and Kubernetes environments.

The exploit only modifies in-memory page cache without changing disk files, bypassing most file integrity monitoring tools.

2. Affected Linux Kernel Range

- **Affected Kernel Version:** Linux Kernel 4.14 ~ 6.18
- **Unaffected:** Kernel version < 4.14
- **Fixed Version:**
 - 6.18.22 and above
 - 6.19.12 and above
 - All Linux Kernel 6.20+ mainline versions

3. Affected Domestic & Foreign Linux Distributions

Category	OS Distribution	Common Kernel Version	Affected Status
Overseas Linux	CentOS 7	3.10	Not Affected
	CentOS 8 / RHEL 8	4.18	Affected
	RHEL 9	5.14	Affected
	Ubuntu 18.04	4.15	Affected
	Ubuntu 20.04	5.4	Affected
	Ubuntu 22.04	5.15	Affected
	Debian 10	4.19	Affected
	Debian 11	5.10	Affected
	Debian 12	6.1	Affected
	SUSE SLES 15	5.3 / 5.15	Affected
	Amazon Linux 2	4.14 / 5.10	Affected
Domestic Xinchuang Linux	Kylin V10	4.19 / 5.4	Affected
	Kylin V11	6.6	Affected
	UnionTech OS V20	4.19 / 5.10 / 5.15	Affected
	openEuler 20.03	4.19	Affected
	openEuler 22.03	5.10	Affected
	Anolis OS 8	4.18	Affected
	Anolis OS 23	5.10 / 6.1	Affected
	Fangde / ZTE New Start	4.19 / 5.x	Affected
	NingSi Security OS	4.19 / 5.4	Affected

4. Temporary Mitigation Solution

For systems that cannot upgrade the kernel immediately, disable the vulnerable `algif\_aead` kernel module as emergency mitigation:

Step 1: Blacklist the module permanently

```
代码块 echo "blacklist algif_aead" > /etc/modprobe.d/algif_aead.conf
```

Step 2: Unload the running module

代码块

```
1 rmmod algif_aead
```

Step 3: Hardening for Container Environment

Restrict AF_ALG socket creation via seccomp policy in Kubernetes, containers and CI/CD environments to block exploit vectors.

5. Fundamental Remediation

1. Upgrade Linux Kernel to 6.18.22 / 6.19.12 or higher official mainline version.
2. For domestic Xinchuang OS, wait and apply the official security patch released by OS vendor.
3. Reinforce access control of multi-tenant servers, disable unnecessary local user interactive permissions.

6. Risk Scenarios to Focus On

- Multi-tenant cloud hosts
- Kubernetes container clusters
- CI/CD execution nodes
- Enterprise internal Xinchuang server environment
- Business hosts with low-privilege user login permission

7. Additional Notes

- The exploit script is publicly available on GitHub (<https://github.com/theori-io/copy-fail-CVE-2026-31431>), so immediate mitigation is recommended.
- Disabling `algif\_aead` module has minimal impact on most systems; only applications explicitly using AF_ALG will fall back to user-space crypto libraries with no obvious performance loss.
- Regularly check for official patches from OS vendors to ensure timely remediation.

(注：文档部分内容可能由 AI 生成)